

Plan Konfiguracji Firewall dla Serwera z Dostępem do Microsoft 365

Poziom Junior - Dokument Planowania

1. ANALIZA WYMAGAŃ

Kontekst biznesowy

Serwer Linux musi wysyłać powiadomienia e-mail przez Microsoft 365 Exchange Online, zawierając wrażliwe dane. Wymaga to zastosowania zasady najmniejszych uprawnień (Principle of Least Privilege).

Wymagania bezpieczeństwa

1. **SSH** - dostęp tylko z sieci lokalnej
2. **Domyślna polityka** - cały ruch wychodzący zablokowany
3. **Wyjątek** - wyłącznie Exchange Online Microsoft 365
4. **Izolacja** - brak dostępu do innych usług internetowych
5. **Audyt** - logowanie wszystkich prób połączeń

Co musi działać (whitelist)

- SMTP do Exchange Online (powiadomienia e-mail)
- HTTPS do serwisów konfiguracyjnych Microsoft 365
- SSH z sieci wewnętrznej (zarządzanie serwerem)
- DNS (wymagany do rozwiązywania nazw domenowych)

Co musi być zablokowane (blacklist)

- Dostęp do internetu z wyjątkiem Microsoft 365
 - HTTP (nieszyfrowany) do Microsoft 365 - tylko HTTPS
 - Wszystkie pozostałe porty i usługi
 - SSH z sieci zewnętrznej
 - Wszystkie pozostałe adresy IP poza Microsoft 365
-

2. RESEARCH MICROSOFT 365 - INFRASTRUKTURA

Domeny wymagane do komunikacji

Na podstawie oficjalnego źródła Microsoft dokumentacji:

Domena	Funkcja	Porty	Kategoria
outlook.office365.com	Główny serwer poczty	TCP 587, 993, 995	SMTP/IMAP/POP3
smtp.office365.com	Serwer SMTP	TCP 587, 25	SMTP (wysyłanie)
outlook.office.com	Portal webowy	TCP 443, 80	HTTPS
*.outlook.com	Serwisy Outlook	TCP 443	HTTPS
autodiscover.outlook.office365.com	Autodiscovery	TCP 443	HTTPS
*.protection.outlook.com	Ochrona przed zagrożeniami	TCP 443	HTTPS
*.mail.protection.outlook.com	Filtrowanie poczty	TCP 25, 587	SMTP
*.mx.microsoft	Wymiana poczty	TCP 25	SMTP

Zakresy adresów IP Microsoft 365

IPv4 - Optimize (obowiązkowe)

13.107.6.152/31	- Outlook
13.107.18.10/31	- Outlook
13.107.128.0/22	- Outlook
23.103.160.0/20	- Outlook
40.96.0.0/13	- Exchange Online
40.104.0.0/15	- Exchange Online
52.96.0.0/14	- Exchange Online
131.253.33.215/32	- Outlook (host)
132.245.0.0/16	- Exchange (region specific)
150.171.32.0/22	- Exchange
204.79.197.215/32	- Outlook (host)

IPv6 - Optimize (obowiązkowe)

2603:1006::/40 - Exchange Online
2603:1016::/36 - Exchange Online
2603:1026::/36 - Exchange Online
2603:1036::/36 - Exchange Online
2603:1046::/36 - Exchange Online
2603:1056::/36 - Exchange Online
2620:1ec:4::152/128 - Outlook (host)
2620:1ec:4::153/128 - Outlook (host)
2620:1ec:c::10/128 - Outlook (host)
2620:1ec:c::11/128 - Outlook (host)
2620:1ec:d::10/128 - Outlook (host)
2620:1ec:d::11/128 - Outlook (host)
2620:1ec:8f0::/46 - Exchange
2620:1ec:900::/46 - Exchange
2620:1ec:a92::152/128 - Outlook (host)
2620:1ec:a92::153/128 - Outlook (host)

IPv4 - Protection (zalecane)

40.92.0.0/15 - Ochrona poczty
40.107.0.0/16 - Ochrona poczty
52.100.0.0/14 - Ochrona poczty
52.238.78.88/32 - Host
104.47.0.0/17 - Filtrowanie

IPv6 - Protection (zalecane)

2a01:111:f400::/48 - Ochrona
2a01:111:f403::/48 - Ochrona

Porty sieciowe - szczegółowa analiza

Port	Protokół	Funkcja	Kierunek	Priorytet
25	TCP	SMTP (wymiana poczty)	OUTBOUND	Wysoki
587	TCP	SMTP (submission)	OUTBOUND	Wysoki
443	TCP	HTTPS (konfiguracja)	OUTBOUND	Wysoki
80	TCP	HTTP (redirect)	OUTBOUND	Niski
993	TCP	IMAPS	OUTBOUND	Średni
995	TCP	POP3S	OUTBOUND	Średni

Port	Protokół	Funkcja	Kierunek	Priorytet
443	UDP	QUIC	OUTBOUND	Niski
22	TCP	SSH	INBOUND	Wysoki
53	UDP	DNS	OUTBOUND	Krytyczny

Uzasadnienie doboru adresów IP

Microsoft publikuje oficjalne zakresy w trzech kategoriach:

- **Optimize (obowiązkowe)** - krytyczne dla funkcjonowania
- **Allow (zalecane)** - zwiększa niezawodność
- **Default (opcjonalne)** - dodatkowe funkcje

Dla wysyłania powiadomień e-mail wystarczą zakresy "Optimize" i "Allow".

3. PLAN REGUŁ FIREWALL

Strategia ogólna

1. Ustaw domyślną politykę DENY dla całego ruchu wychodzącego
2. Ustaw domyślną politykę ACCEPT dla ruchu przychodzącego (będzie zawężany)
3. Aplikuj reguły w ścisłej kolejności (od bardziej sprecyzowanych do bardziej ogólnych)
4. Zablokuj najpierw co niebezpieczne, potem pozwól na konkretne usługi

Sekwencja reguł (KOLEJNOŚĆ JEST WAŻNA)

Faza 1: Ruch przychodzący (INBOUND)

Reguła 1: Zablokuj SSH z sieci zewnętrznej

- Kierunek: INBOUND
- Port: 22 (SSH)
- Źródło: 0.0.0.0/0 (wszędzie)
- Akcja: DENY
- Uzasadnienie: Zabezpieczenie przed próbami nieautoryzowanego dostępu

Reguła 2: Pozwól SSH z sieci lokalnej

- Kierunek: INBOUND
- Port: 22 (SSH)
- Źródło: 10.0.0.0/8 lub 192.168.0.0/16 (sieć lokalna)
- Akcja: ACCEPT
- Uzasadnienie: Administracja serverem z sieci wewnętrznej

Reguła 3: Pozwól ESTABLISHED i RELATED

- Kierunek: INBOUND
- Stan: ESTABLISHED, RELATED
- Akcja: ACCEPT
- Uzasadnienie: Odpowiedzi na połączenia wychodzące

Faza 2: Ruch wychodzący (OUTBOUND)

Prioritet 1 - Wysyłanie poczty (SMTP)

Reguła 4: Port 25 (SMTP) do Exchange Online

- Kierunek: OUTBOUND
- Cel: Microsoft 365 IP ranges (*.mx.microsoft)
- Port: 25 (TCP)
- IP ranges: 40.92.0.0/15, 40.107.0.0/16, 52.100.0.0/14, 104.47.0.0/17
- Akcja: ACCEPT
- Uzasadnienie: Wymiana poczty z serwerami Microsoft 365

Reguła 5: Port 587 (SMTP Submission) do Exchange Online

- Kierunek: OUTBOUND
- Cel: outlook.office365.com
- Port: 587 (TCP)
- IP ranges: 13.107.6.152/31, 13.107.18.10/31, 13.107.128.0/22,
23.103.160.0/20, 40.96.0.0/13, 40.104.0.0/15, 52.96.0.0/14,
131.253.33.215/32, 132.245.0.0/16, 150.171.32.0/22, 204.79.197.215/32
- Akcja: ACCEPT
- Uzasadnienie: Submission portu dla aplikacji mail (TLS)

Prioritet 2 - HTTPS (konfiguracja i bezpieczeństwo)

Reguła 6: Port 443 (HTTPS) do outlook.office365.com

- Kierunek: OUTBOUND
- Cel: outlook.office365.com
- Port: 443 (TCP)
- IP ranges: 13.107.6.152/31, 13.107.18.10/31, 13.107.128.0/22,
23.103.160.0/20, 40.96.0.0/13, 40.104.0.0/15, 52.96.0.0/14
- Akcja: ACCEPT
- Uzasadnienie: Konfiguracja, autodiscover i szyfrowana komunikacja

Reguła 7: Port 443 (HTTPS) do *.protection.outlook.com

- Kierunek: OUTBOUND
- Cel: *.protection.outlook.com
- Port: 443 (TCP)
- IP ranges: 40.92.0.0/15, 40.107.0.0/16, 52.100.0.0/14, 52.238.78.88/32, 104.47.0.0/17
- Akcja: ACCEPT
- Uzasadnienie: Ochrona przed zagrożeniami, skanowanie ZAP

Prioritet 3 - DNS (krytyczne)

Reguła 8: Port 53 (DNS) do downstreamów DNS

- Kierunek: OUTBOUND
- Cel: 8.8.8.8, 1.1.1.1 (lub wewnętrzny DNS server)
- Port: 53 (UDP)
- Akcja: ACCEPT
- Uzasadnienie: Wymagane do rozwiązywania nazw domenowych Microsoft 365

Prioritet 4 - Pozostałe protokoły (opcjonalnie)

Reguła 9: Port 993 (IMAPS) do outlook.office365.com [OPCJONALNE]

- Kierunek: OUTBOUND
- Port: 993 (TCP)
- Akcja: ACCEPT
- Uzasadnienie: Jeśli wymaga się odbierania poczty (czasami nie jest konieczne)

Reguła 10: Port 995 (POP3S) do outlook.office365.com [OPCJONALNE]

- Kierunek: OUTBOUND
- Port: 995 (TCP)
- Akcja: ACCEPT
- Uzasadnienie: Jeśli wymaga się odbierania poczty (rzadko stosowane)

Faza 3 - Default DENY

Reguła 11: Zablokuj wszystkie pozostałe połączenia wychodzące

- Kierunek: OUTBOUND
- Źródło: 0.0.0.0/0
- Akcja: DENY
- Uzasadnienie: Domyślna polityka - żaden inny ruch nie jest dozwolony

4. IDENTYFIKACJA PORTÓW - SZCZEGÓŁOWA ANALIZA

Porty obowiązkowe dla SMTP (wysyłanie powiadomień)

Port 25 - SMTP (Simple Mail Transfer Protocol)

- **Użycie:** Wymiana poczty między serwerami
- **Szyfrowanie:** Brak (legacy)
- **Zastosowanie:** Punkt-do-punktu między MTA
- **Status:** Czasami blokowany przez ISP
- **Wymagane zakresy IP:** *.mx.microsoft ranges

Port 587 - SMTP Submission (TLS)

- **Użycie:** Wysyłanie poczty przez aplikacje
- **Szyfrowanie:** STARTTLS (obowiązkowe)
- **Zastosowanie:** Rekomendowane dla aplikacji
- **Status:** Standard dla nowoczesnych systemów
- **Wymagane zakresy IP:** outlook.office365.com ranges

Port 443 - HTTPS (TLS/SSL)

- **Użycie:** Konfiguracja, autodiscover, API REST
- **Szyfrowanie:** TLS 1.2+
- **Zastosowanie:** Bezpieczna komunikacja web
- **Status:** Standard dla všech serwisów web
- **Wymagane zakresy IP:** outlook.office365.com, *.protection.outlook.com

Porty fakultatywne (nie są potrzebne do wysyłania)

Port 993 - IMAPS (Secure IMAP)

- **Użycie:** Odbieranie poczty (IMAP)

- **Szyfrowanie:** TLS
- **Zastosowanie:** Jeśli serwer musi czyć maile
- **Status:** Opcjonalnie dla backupu/archiwizacji

Port 995 - POP3S (Secure POP3)

- **Użycie:** Odbieranie poczty (POP3)
- **Szyfrowanie:** TLS
- **Zastosowanie:** Rzadkie, legacy protocol
- **Status:** Nie rekomenduje się

Port 53 - DNS (wymagany dla wszystkich)

- **Użycie:** Rozwiązywanie nazw domenowych
- **Protokół:** UDP
- **Zastosowanie:** Wymagane do znalezienia serwerów Microsoft 365
- **Status:** Absolutnie obowiązkowy

Port 80 - HTTP (opcjonalnie)

- **Użycie:** Redirect do HTTPS
- **Szyfrowanie:** Brak
- **Zastosowanie:** Niskie priorytetu
- **Status:** Można zablokować (HTTPS wystarczy)

5. PLAN TESTOWANIA

Cel testowania

Weryfikacja, że firewall:

1. Pozwala na wysyłanie powiadomień e-mail
2. Blokuje cały pozostały ruch wychodzący
3. Pozwala na SSH z sieci lokalnej
4. Rejestruje wszystkie zdarzenia

Środowisko testowe

- **Serwer testowy:** Dedykowana VM z Ubuntu/Debian i UFW
- **Klient:** Druga maszyna w sieci lokalnej

- **Monitorowanie:** Logi UFW i tcpdump

Test 1: Sprawdzenie SSH z sieci lokalnej

Procedura:

```
bash

# Z maszyny lokalnej (10.0.0.50)
ssh user@serwer.local
```

Oczekiwany rezultat: Połączenie udane **Jak weryfikować:** Pomyślne zalogowanie

Logi do sprawdzenia:

```
bash

grep "22.*ACCEPT" /var/log/ufw.log
```

Test 2: Blokada SSH z sieci zewnętrznej

Procedura:

```
bash

# Z maszyny zewnętrznej (symulacja)
ssh -p 22 user@public.ip.of.server
```

Oczekiwany rezultat: Connection refused/timeout **Jak weryfikować:** Timeout po ~30 sekundach

Logi do sprawdzenia:

```
bash

grep "22.*REJECT" /var/log/ufw.log
```

Test 3: Wysyłanie testowego e-mail (SMTP port 587)

Procedura:

```
bash
```

```
# Na serwerze
```

```
telnet smtp.office365.com 587
```

```
# Lub za pomocą openssl
```

```
openssl s_client -connect smtp.office365.com:587 -starttls smtp
```

Oczekiwany rezultat:

- Połączenie nawiązane
- Odpowiedź serwera: (220 ...)

Jak weryfikować: Widok promptu serwera SMTP

Logi do sprawdzenia:

```
bash
```

```
grep "587.*ACCEPT" /var/log/ufw.log
```

Test 4: Blokada portu 25 jeśli niechciany

Procedura:

```
bash
```

```
# Na serwerze
```

```
telnet smtp.office365.com 25
```

Oczekiwany rezultat: Connection refused (jeśli port 25 jest zablokowany)

Logi do sprawdzenia:

```
bash
```

```
grep "25.*REJECT" /var/log/ufw.log
```

Test 5: Blokada dostępu do zewnętrznych serwisów

Procedura:

```
bash
```

```
# Na serwerze - próba połączenia do Google
```

```
telnet 8.8.8.8 80
```

```
curl http://example.com
```

```
# Lub próba HTTPS do zewnętrznego serwisu
```

```
openssl s_client -connect example.com:443
```

Oczekiwany rezultat: Connection refused/timeout

Logi do sprawdzenia:

```
bash
```

```
grep "REJECT" /var/log/ufw.log | grep -v outlook | grep -v protection
```

Test 6: Weryfikacja DNS

Procedura:

```
bash
```

```
# Na serwerze
```

```
nslookup outlook.office365.com
```

```
dig smtp.office365.com
```

```
host mail.protection.outlook.com
```

Oczekiwany rezultat: Pomyślne rozwiązanie nazwy

Logi do sprawdzenia:

```
bash
```

```
tcpdump -i eth0 'udp port 53' -n
```

Test 7: Całościowy test wysyłania poczty

Procedura:

```
bash
```

```
# Na serwerze - użycie mail command
```

```
echo "Test email body" | mail -s "Test" user@example.com
```

```
# Lub za pomocą python/smtplib
```

```
python3 << 'EOF'
```

```
import smtplib
```

```
server = smtplib.SMTP("smtp.office365.com", 587)
```

```
server.starttls()
```

```
server.login("user@company.onmicrosoft.com", "password")
```

```
server.sendmail("user@company.onmicrosoft.com", "recipient@example.com", "Test")
```

```
server.quit()
```

```
print("Success")
```

```
EOF
```

Oczekiwany rezultat: E-mail wysłany pomyślnie

Logi do sprawdzenia:

```
bash
```

```
tail -50 /var/log/ufw.log | grep ACCEPT
```

6. STRATEGIA MONITORINGU

Logi UFW - lokalizacja

```
/var/log/ufw.log      - Główny plik logów
```

```
/var/log/syslog        - Systemowe logi (na niektórych systemach)
```

```
/var/log/auth.log      - SSH authentication logi
```

Włączenie logowania UFW

Sprawdzenie obecnego poziomu:

```
bash
```

```
sudo ufw status verbose
```

Ustawienie wysokiego poziomu logowania:

```
bash
```

```
sudo ufw logging high
```

Monitorowane zdarzenia

1. Ruch SMTP (port 587) - wysyłanie poczty

```
bash

# Logi pomyślnych połączeń
grep "587.*ACCEPT" /var/log/uFW.log

# Format logu:
# [UFW ALLOW] IN=eth0 OUT=eth0 SRC=10.0.0.5 DST=13.107.18.10 DPORT=587 PROTO=tcp
```

Co szukać: Połączenia do zakresu `13.107.x.x` lub `40.96.0.0/13` **Częstotliwość:** Powinna być regularna (co X minut/godzin zależnie od harmonogramu wysyłania) **Alerty:** Jeśli brakuje połączeń - możliwy problem z wysyłaniem

2. Ruch HTTPS (port 443) - autodiscover

```
bash

# Logi HTTPS
grep "443.*ACCEPT" /var/log/uFW.log

# Filtr na outlook.office365.com ranges
grep "443.*ACCEPT.*13.107|40.96|40.104" /var/log/uFW.log
```

Co szukać: Połączenia do zakresu `13.107.x.x` lub `40.x.x.x` **Częstotliwość:** Okazjonalne (zazwyczaj podczas startu aplikacji lub konfiguracji) **Alerty:** Jeśli brakuje - możliwy problem z konfiguracją

3. Ruch DNS (port 53) - rozwiązywanie nazw

```
bash

# Logi DNS
grep "53.*ACCEPT" /var/log/uFW.log

# Bezpośrednio z tcpdump
sudo tcpdump -i eth0 'udp port 53' -n | grep outlook
```

Co szukać: Zapytania DNS o `outlook.office365.com`, `smtp.office365.com` **Częstotliwość:** Powinna być na początku każdego nowego połączenia **Alerty:** Jeśli brakuje - DNS możliwie skonfigurowany lokalnie lub cache

4. Próby nieautoryzowanego dostępu - SSH

```
bash
```

```
# Zablokowane próby SSH
```

```
grep "22.*REJECT\|DROP" /var/log/ufw.log
```

```
# Z filtrem na sieci zewnętrzne
```

```
grep "22.*REJECT" /var/log/ufw.log | grep -v "10.0.0\|192.168"
```

Co szukać: Połączenia z IP poza siecią wewnętrzną **Częstotliwość:** Powinna być minimalna (tylko próby ataków) **Alerty:** Jeśli duża liczba - serwer może być celem ataku

5. Próby dostępu do zakazanych serwisów

```
bash
```

```
# Wszystkie REJECT/DROP
```

```
grep "REJECT\|DROP" /var/log/ufw.log
```

```
# Bez Microsoft 365 ranges
```

```
grep "REJECT\|DROP" /var/log/ufw.log | grep -v "13.107\|40.92\|40.96\|40.104\|40.107\|52.96\|52.100"
```

Co szukać: Próby połączeń do IP spoza allowlist'y **Częstotliwość:** Powinna być bardzo niska **Alerty:** Jeśli je ma - możliwy błąd w konfiguracji aplikacji lub attempt ataku

Narzędzia monitoringu

1. Real-time monitoring logów

```
bash
```

```
# Obserwacja na żywo
```

```
sudo tail -f /var/log/ufw.log
```

```
# Z grepem na port SMTP
```

```
sudo tail -f /var/log/ufw.log | grep 587
```

2. Analiza historyczna

```
bash
```

```
# Statystyka połączeń w ostatnich 24h
```

```
grep "$(date -d '24 hours ago' +%b %d)" /var/log/ufw.log | wc -l
```

```
# Liczba ACCEPT w ostatnich 24h
```

```
grep "$(date -d '24 hours ago' +%b %d)" /var/log/ufw.log | grep ACCEPT | wc -l
```

```
# Liczba REJECT w ostatnich 24h
```

```
grep "$(date -d '24 hours ago' +%b %d)" /var/log/ufw.log | grep REJECT | wc -l
```

3. Monitorowanie portów sieciowych

```
bash

# Aktywne połączenia
sudo netstat -tulpn | grep ESTABLISHED

# Lub nowsze narzędzie
sudo ss -tulpn | grep ESTABLISHED

# Filtr na port 587
sudo ss -tulpn | grep 587
```

4. Tcpdump - sniffing ruchu sieciowego

```
bash

# Monitorowanie całego ruchu SMTP
sudo tcpdump -i eth0 'tcp port 587' -n

# Zapis do pliku
sudo tcpdump -i eth0 'tcp port 587' -w smtp_traffic.pcap

# Z hostname'ami
sudo tcpdump -i eth0 'tcp port 587'

# Z payload'em (ostrożnie!)
sudo tcpdump -i eth0 'tcp port 587' -A
```

5. Analiza firewall'a

```
bash

# Status UFW
sudo ufw status numbered

# Statystyka logów
grep -o "DPT=[0-9]*" /var/log/ufw.log | sort | uniq -c | sort -rn

# IP adres z największą liczbą prób
grep "REJECT" /var/log/ufw.log | grep -o "SRC=[0-9.]*" | sort | uniq -c | sort -rn
```

Scenariusze diagnostyczne

Scenarij 1: Poczta nie wysyła się

bash

Sprawdzenie logów aplikacji mail

`tail -50 /var/log/mail.log`

Sprawdzenie czy reguła 587 istnieje

`sudo ufw status numbered | grep 587`

Test TCP do serwera SMTP

`sudo tcpdump -i eth0 'host smtp.office365.com and port 587' -n`

Próba ręcznego połączenia

`openssl s_client -connect smtp.office365.com:587 -starttls smtp`

Scenario 2: Serwer ma dostęp do internetu, którego nie powinien mieć

bash

Szukaj ACCEPT na portach inne niż 587, 443, 53, 22

`grep "ACCEPT" /var/log/ufw.log | grep -v "DPT=587\|DPT=443\|DPT=53\|DPT=22"`

Sprawdzenie aktualnych reguł

`sudo ufw status numbered`

Może brakuje default DENY na outbound

`sudo ufw show added`

Scenario 3: SSH nie działa z sieci lokalnej

bash

Sprawdzenie czy port 22 jest otwarty

`sudo ufw status numbered | grep 22`

Test TCP do port 22 z IP lokalnego

`telnet localhost 22`

Logów ssh auth

`tail -30 /var/log/auth.log | grep ssh`

Alerting i powiadomienia (manual)

Rekomendowana częstotliwość sprawdzenia logów:

- Co godzinę: Liczba REJECT (anomalie = alertem)
- Codziennie: Podsumowanie połączeń SMTP

- Tygodniowo: Raport bezpieczeństwa (SSH attempts, podejrzane porty)

Kryteria alertu:

- Liczba REJECT > 100 w godzinę = anomalia
 - Brak połączeń SMTP > 24h = błąd
 - SSH attempt z IP zewnętrznego = uwaga
 - Połączenie na port inny niż allowlist = krytyczne
-

PODSUMOWANIE PLANU

Fazy implementacji

1. **Faza 1 - Przygotowanie:** Zdefiniowanie sieci lokalnej i adresów IP
2. **Faza 2 - Konfiguracja:** Implementacja reguł UFW
3. **Faza 3 - Testowanie:** Weryfikacja każdej reguły
4. **Faza 4 - Monitorowanie:** Ustawienie logowania i obserwacji

Dokumenty referencyjne

- Microsoft 365 Endpoints: <https://docs.microsoft.com/en-us/microsoft-365/enterprise/urls-and-ip-address-ranges>
- UFW Manual: `man ufw`
- Postfix/Exim Logs: `/var/log/mail.log`
- Syslog: `/var/log/syslog`

Metryki sukcesu

- Wszystkie testy przechodzą pozytywnie
- Brak błędów wysyłania poczty
- UFW logs pokazują poprawne przepuszczanie tylko reguł
- SSH dostępny tylko z sieci wewnętrznej
- Żaden inny ruch wychodzący nie jest przepuszczany